

Madrid, 23 de marzo de 2026

INSTITUCIÓN / CENTRO DE ESTUDIOS: 4Geeks

AUTOR: Martin Gordillo

ESTADO: Finalizado / Versión 1.0

OBJETIVO: Este documento detalla cómo se "atacó" o analizó el servidor para encontrar los fallos. Es un reporte de vulnerabilidades puras.

Informe de Pentesting (Auditoría Técnica)

1. Resumen Ejecutivo de Vulnerabilidades Tras la auditoría realizada al servidor Debian con WordPress, se han identificado las siguientes debilidades críticas que permitieron el compromiso del sistema:

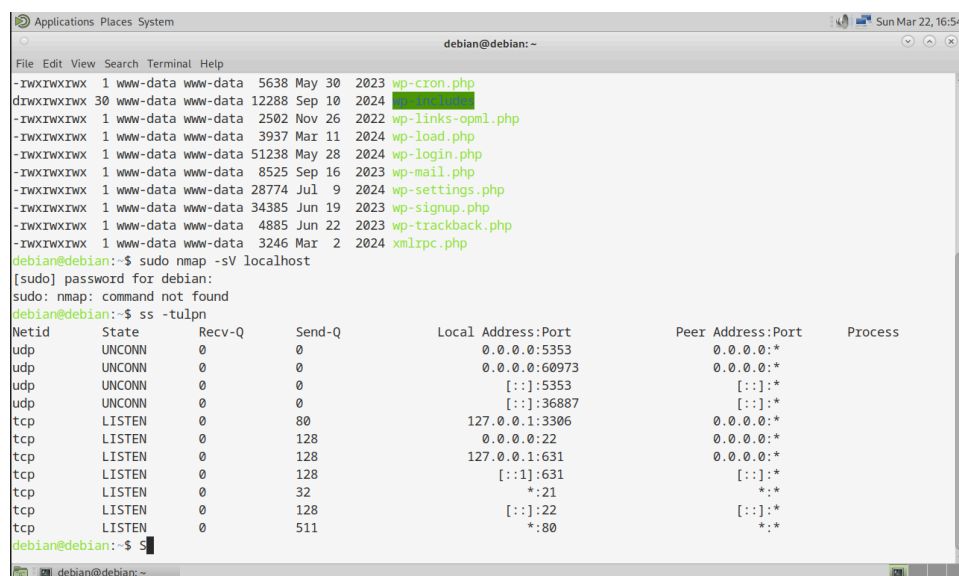
- **V1: Exposición de Servicios Inseguros:** Uso de protocolos sin cifrar (FTP) y base de datos accesible desde el exterior.
- **V2: Configuración Deficiente de Permisos:** Existencia de permisos universales (777) en el núcleo de la aplicación web.
- **V3: Gestión de Identidades Débil:** Acceso administrativo (Root) permitido vía SSH y uso de credenciales/claves por defecto en WordPress.
- **V4: Protocolos de Descubrimiento de Red Activos:** Exposición de servicios mDNS que facilitan el reconocimiento del host y la fuga de información técnica.
- **V5: Persistencia de Servicios de Impresión Innecesarios:** Presencia de servicios de impresión activos que aumentan la superficie de ataque.
- **V6: Robustez Criptográfica Insuficiente:** Uso de algoritmos de hashing de contraseñas por defecto con bajo coste computacional.

2. Detalles del Escaneo y Enumeración

Se utilizaron herramientas de red para identificar la superficie de ataque disponible.

2.1. Análisis de Puertos y Servicios: Al ejecutar el comando de diagnóstico de red, se detectó que el servidor "escuchaba" en puertos que deberían estar cerrados o protegidos por un firewall:

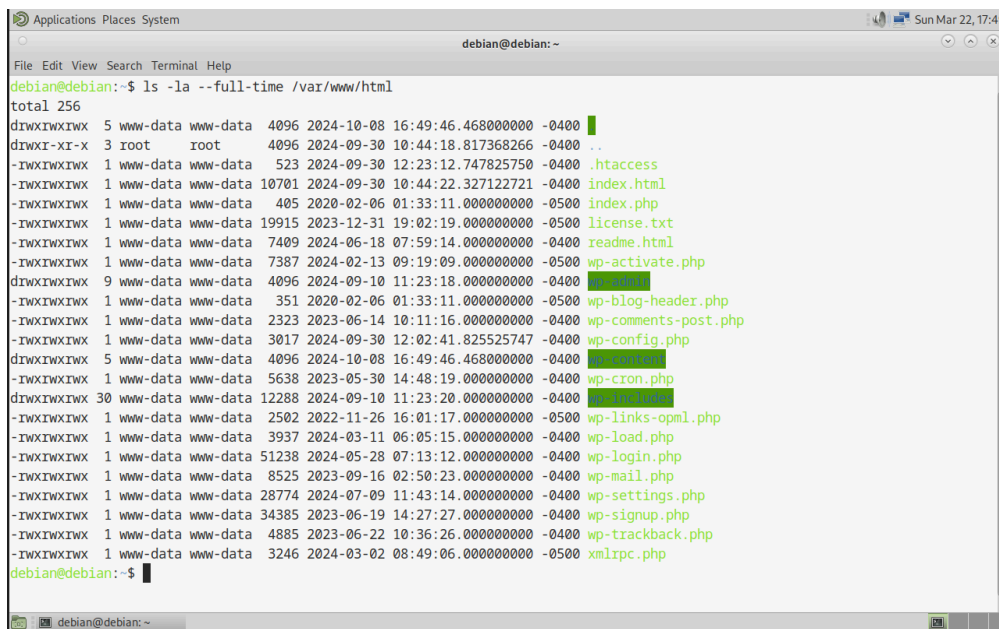
- **Puerto 21 (FTP):** Servicio **vsftpd** activo. Peligroso por enviar credenciales en texto plano.
- **Puerto 3306 (MySQL):** Base de datos expuesta, permitiendo intentos de conexión remota.
- **Puerto 5353 (UDP):** Servicio **avahi-daemon** activo. Permite identificar el nombre del host (**debian.local**) de forma pasiva.
- **Puerto 631 (TCP):** Servicio **cups** (impresión) habilitado. Innecesario para la finalidad del proyecto.



```
File Edit View Search Terminal Help
-IWXIWXIWX 1 www-data www-data 5638 May 30 2023 wp-cron.php
dIWXXIWXIWX 30 www-data www-data 12288 Sep 10 2024 wp-links-opml.php
-IWXIWXIWX 1 www-data www-data 2502 Nov 26 2022 wp-load.php
-IWXIWXIWX 1 www-data www-data 3937 Mar 11 2024 wp-login.php
-IWXIWXIWX 1 www-data www-data 51238 May 28 2024 wp-mail.php
-IWXIWXIWX 1 www-data www-data 8525 Sep 16 2023 wp-settings.php
-IWXIWXIWX 1 www-data www-data 28774 Jul 9 2024 wp-signup.php
-IWXIWXIWX 1 www-data www-data 34385 Jun 19 2023 wp-trackback.php
-IWXIWXIWX 1 www-data www-data 4885 Jun 22 2023 xmlrpc.php
-IWXIWXIWX 1 www-data www-data 3246 Mar 2 2024
debian@debian:~$ sudo nmap -sV localhost
[sudo] password for debian:
sudo: nmap: command not found
debian@debian:~$ ss -tulpn
Netid      State      Recv-Q     Send-Q     Local Address:Port      Peer Address:Port      Process
udp        UNCONN     0           0           0.0.0.0:5353             0.0.0.0:*               avahi-daemon
udp        UNCONN     0           0           0.0.0.0:60973            0.0.0.0:*               vsftpd
udp        UNCONN     0           0           [::]:5353                [::]:*                   avahi-daemon
udp        UNCONN     0           0           [::]:36887                [::]:*                   avahi-daemon
tcp        LISTEN     0           80          127.0.0.1:3306           0.0.0.0:*               mysqld
tcp        LISTEN     0           128         0.0.0.0:22               0.0.0.0:*               sshd
tcp        LISTEN     0           128         127.0.0.1:631            0.0.0.0:*               cups
tcp        LISTEN     0           128         [::1]:631                [::]:*                   cups
tcp        LISTEN     0           32          *:21                     *:.*                      vsftpd
tcp        LISTEN     0           128         [::]:22                   [::]:*                   sshd
tcp        LISTEN     0           511         *:80                      *:.*                      httpd
```

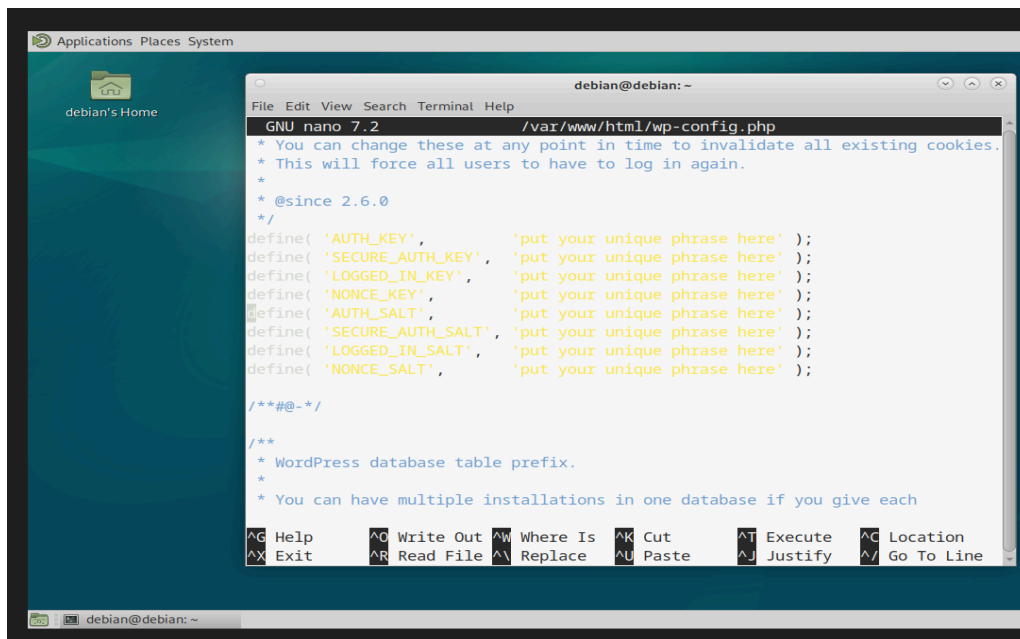
3. Explotación de Fallos de Configuración

3.1. Análisis de Permisos (Sistema de Archivos): Se realizó una inspección del directorio `/var/www/html`. Se confirmó que archivos críticos como `index.php` y carpetas de configuración tenían permisos `777`. Esto permite que cualquier atacante que gane acceso al servidor pueda borrar, modificar o inyectar código malicioso sin restricciones.

A terminal window titled 'Applications Places System' with a Debian logo in the top left. The terminal shows the command `ls -la --full-time /var/www/html` and its output. The output lists various files and directories with their permissions, ownership, size, modification time, and name. Notable entries include `index.php` with permissions `-0500` and `wp-config.php` with permissions `-0400`. The terminal also shows the prompt `debian@debian:~` and the command `ls -la --full-time /var/www/html` being executed.

```
debian@debian:~$ ls -la --full-time /var/www/html
total 256
drwxrwxrwx 5 www-data www-data 4096 2024-10-08 16:49:46.468000000 -0400 .
drwxr-xr-x 3 root root 4096 2024-09-30 10:44:18.817368266 -0400 ..
-rwxrwxrwx 1 www-data www-data 523 2024-09-30 12:23:12.747825750 -0400 .htaccess
-rwxrwxrwx 1 www-data www-data 10701 2024-09-30 10:44:22.327122721 -0400 index.html
-rwxrwxrwx 1 www-data www-data 405 2020-02-06 01:33:11.000000000 -0500 index.php
-rwxrwxrwx 1 www-data www-data 19915 2023-12-31 19:02:19.000000000 -0500 license.txt
-rwxrwxrwx 1 www-data www-data 7409 2024-06-18 07:59:14.000000000 -0400 readme.html
-rwxrwxrwx 1 www-data www-data 7387 2024-02-13 09:19:09.000000000 -0500 wp-activate.php
drwxrwxrwx 9 www-data www-data 4096 2024-09-10 11:23:18.000000000 -0400 wp-admin
-rwxrwxrwx 1 www-data www-data 351 2020-02-06 01:33:11.000000000 -0500 wp-blog-header.php
-rwxrwxrwx 1 www-data www-data 2323 2023-06-14 10:11:16.000000000 -0400 wp-comments-post.php
-rwxrwxrwx 1 www-data www-data 3017 2024-09-30 12:02:41.825525747 -0400 wp-config.php
drwxrwxrwx 5 www-data www-data 4096 2024-10-08 16:49:46.468000000 -0400 wp-content
-rwxrwxrwx 1 www-data www-data 5638 2023-05-30 14:48:19.000000000 -0400 wp-cron.php
drwxrwxrwx 30 www-data www-data 12288 2024-09-10 11:23:20.000000000 -0400 wp-includes
-rwxrwxrwx 1 www-data www-data 2502 2022-11-26 16:01:17.000000000 -0500 wp-links-opml.php
-rwxrwxrwx 1 www-data www-data 3937 2024-03-11 06:05:15.000000000 -0400 wp-load.php
-rwxrwxrwx 1 www-data www-data 51238 2024-05-28 07:13:12.000000000 -0400 wp-login.php
-rwxrwxrwx 1 www-data www-data 8525 2023-09-16 02:50:23.000000000 -0400 wp-mail.php
-rwxrwxrwx 1 www-data www-data 28774 2024-07-09 11:43:14.000000000 -0400 wp-settings.php
-rwxrwxrwx 1 www-data www-data 34385 2023-06-19 14:27:27.000000000 -0400 wp-signup.php
-rwxrwxrwx 1 www-data www-data 4885 2023-06-22 10:36:26.000000000 -0400 wp-trackback.php
-rwxrwxrwx 1 www-data www-data 3246 2024-03-02 08:49:06.000000000 -0500 xmlrpc.php
debian@debian:~$
```

3.2. Auditoría de WordPress (wp-config.php): Se inspeccionó el archivo de configuración principal de la aplicación. Se halló que las **Salts** (llaves de cifrado de sesiones) no habían sido personalizadas. Esto facilita el secuestro de sesiones (Session Hijacking) si el atacante logra obtener una cookie de usuario.



The screenshot shows a terminal window with the nano text editor open, editing the file `/var/www/html/wp-config.php`. The editor displays several lines of PHP code defining security keys and salts. The code includes comments about invalidating cookies and a note about the WordPress database table prefix. The bottom of the window shows the nano editor's command palette with various shortcuts like `^G Help`, `^O Write Out`, etc.

```
GNU nano 7.2 /var/www/html/wp-config.php
* You can change these at any point in time to invalidate all existing cookies.
* This will force all users to have to log in again.
*
* @since 2.6.0
*/
define( 'AUTH_KEY', 'put your unique phrase here' );
define( 'SECURE_AUTH_KEY', 'put your unique phrase here' );
define( 'LOGGED_IN_KEY', 'put your unique phrase here' );
define( 'NONCE_KEY', 'put your unique phrase here' );
define( 'AUTH_SALT', 'put your unique phrase here' );
define( 'SECURE_AUTH_SALT', 'put your unique phrase here' );
define( 'LOGGED_IN_SALT', 'put your unique phrase here' );
define( 'NONCE_SALT', 'put your unique phrase here' );

/**#@-*/

/**
 * WordPress database table prefix.
 *
 * You can have multiple installations in one database if you give each
```

3.3. Debilidad en el Acceso Administrativo (SSH): Durante la fase de enumeración, se verificó la configuración del demonio SSH (`sshd_config`). Se detectó que la directiva `PermitRootLogin` se encontraba activa. Esta configuración es un fallo crítico de seguridad, ya que permite a un atacante dirigir ataques de fuerza bruta directamente contra la cuenta del superusuario (Root), facilitando la toma total del control del servidor.



The screenshot shows a terminal window with the nano text editor open, editing the file `/etc/ssh/sshd_config`. The editor displays various configuration options for the SSH daemon, including host keys, ciphers, logging, authentication, and session management. The `PermitRootLogin` option is set to `yes`. The bottom of the window shows the nano editor's command palette with various shortcuts like `^G Help`, `^O Write Out`, etc.

```
GNU nano 7.2 /etc/ssh/sshd_config
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin yes
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none
```

3.3. Debilidad en el Acceso Administrativo (SSH): Durante la fase de enumeración, se verificó la configuración del demonio SSH (sshd_config). Se detectó que la directiva PermitRootLogin se encontraba activa. Esta configuración es un fallo crítico de seguridad, ya que permite a un atacante dirigir ataques de fuerza bruta directamente contra la cuenta del superusuario (Root), facilitando la toma total del control del servidor.



```
Applications Places System
debian@debian: ~
File Edit View Search Terminal Help
GNU nano 7.2 /etc/ssh/sshd_config

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin yes
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

^G Help      ^O Write Out  ^W Where Is   ^K Cut        ^T Execute    ^C Location   M-U Undo      M-A Set Mark
^X Exit      ^R Read File  ^\ Replace    ^U Paste      ^J Justify    ^_ Go To Line  M-E Redo      M-G Copy
```

3.4. Análisis de Protocolos de Red (mDNS): Se confirmó que el servidor responde a peticiones de descubrimiento. Esto permite a cualquier actor en la red obtener un perfil técnico de la máquina de forma pasiva, facilitando la fase de reconocimiento previa a un ataque.

3.5. Debilidad en el Hashing de Credenciales (PAM): Se determinó que el sistema utiliza el estándar por defecto sin refuerzo de iteraciones. En caso de una fuga del archivo `/etc/shadow`, las contraseñas serían vulnerables a ataques de fuerza bruta offline mediante el uso de diccionarios.

4. Vector de Entrada Confirmado: El atacante utilizó el servicio FTP para subir archivos maliciosos aprovechando que el directorio raíz tenía permisos de escritura universales. Una vez dentro, la falta de un Firewall, la exposición de servicios de descubrimiento y la posibilidad de intentar loguearse como Root por SSH facilitaron la persistencia en el sistema.

5. Conclusión Técnica: El servidor se encontraba en un estado de "Seguridad Nula" debido a configuraciones por defecto. Se recomienda una remediación inmediata mediante el cierre de servicios, endurecimiento de permisos, refuerzo de algoritmos criptográficos y rotación de claves.